



An inline security proxy for EV charging networks.

Transparent OCPP 1.6-J reverse proxy that inspects every WebSocket frame in real time and quarantines compromised chargers before they reach the backend or destabilise the grid.

Public EV charging runs on **weakly-authed WebSockets**.

- Chargers speak OCPP 1.6-J — JSON frames over a persistent WebSocket to a central management system (CSMS).
- Stations are physically exposed roadside hardware on connections that are often barely authenticated.
- They are soft cyber-physical edge nodes sitting on critical energy infrastructure.

- **Why it isn't already solved**

Cloud CSMS platforms audit after the fact — batch analysis minutes or hours after ingestion, long after an attack has landed.

Hardware retrofits are economically dead — you cannot ship a firewall chip to millions of deployed stations.

Four attack vectors on the charging control plane.

- **Meter spoofing**

Under-report delivered energy so a session bills near zero while real power flows. Billing fraud at fleet scale.

- **Grid oscillation**

Synchronised rapid start/stop of high-power chargers across a cluster to swing local load and trip a distribution transformer.

- **Session shadowing**

A parallel WebSocket handshake reusing a live `chargePointId` to displace or seize a legitimate charger's session.

- **Subtle data drift**

Slow compounding falsification that stays inside every hard threshold — invisible to any rule engine.

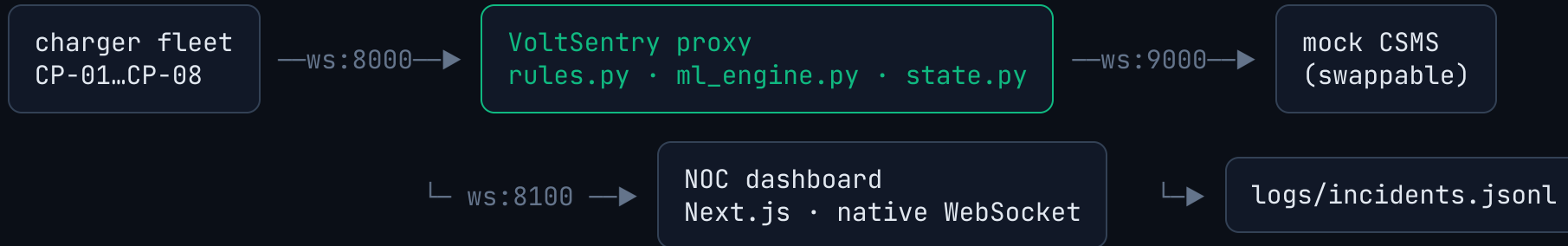
Pure software at the **transport layer**.

- A transparent reverse proxy between the charger and the CSMS. Clean traffic is relayed 8000 → 9000 untouched, both directions.
- Sub-millisecond design budget. No hardware change. Drop-in in front of an existing CSMS — the backend never knows it's there.
- Every frame is parsed, the session state machine is enforced, and a dual-tier detection engine scores it before it is forwarded.
- On a Tier-1 block: drop the frame, send `ChangeAvailability` to the charger, close the socket 4001.

● **Station identity**

Taken from the URL path — `ws://.../ocpp/CP-04` — parsed at handshake, before any frame arrives. The proxy opens the matching upstream socket per station and keeps a pending call map so a `CALLRESULT` can be correlated to the `CALL` that produced it.

One process on the wire. Two detection tiers. One live feed.



- OCPP frames are JSON **arrays** — `[2,id,action,payload]` / `[3,id,payload]` / `[4,id,code,desc,details]`. A CALLRESULT carries no action name; the proxy correlates it itself.
- The dashboard feed is a **separate** plain WebSocket on `:8100` — no Socket.io, no path-routing on the OCPP port.

Tier-1 catches the loud attacks at **zero latency**.

RULE	CHECKS	TRIPS WHEN	ACTION
R1_STATE_ORDER	per-station FSM	MeterValues / StopTransaction with no live Authorize → StartTransaction	log
R2_PHYSICS	CC-CV envelope	power > 150 kW, or > 60 kW while SoC > 80%, or < 0	quarantine
R3_OSCILLATION	sliding window	≥ 6 start/stop transitions fleet-wide in 10 s	log
R4_SESSION_UNIQUE	connection registry	second handshake for a cpid with a live session	reject at handshake
R5_TXN_INTEGRITY	transaction map	MeterValues.transactionId unknown or owned by another cpid	quarantine
R6_METER_FRAUD	energy-residual rate	reported energy register pulling away from reported power faster than an honest session ever does	quarantine

Tier-2 catches the one attack a rule cannot.

- Subtle drift stays inside every hard threshold by construction — so it is not a point outlier and a threshold engine stays silent.
- The fix is an engineered feature the proxy computes from the wire alone: $\text{energy_residual} = \text{reported register} - \int \text{reported power dt}$.
- Honest sessions hold this near zero. Any divergence between reported instantaneous power and the accumulating energy register makes it climb monotonically.
- Scored two ways: an **Isolation Forest** on the 5-dim session vector, and an offline **CUSUM** change-detector on the residual for corroboration and explainability.

● The 5-dim vector

```
[ power_kw,  
  soc,  
  dp_dt,  
  duration_sec,  
  energy_residual_kwh ]
```

IsolationForest(n_estimators=100,
contamination=0.02, random_state=42), score
normalisation pinned at fit time. Alert on score > 0.65. Samples
1-2 of a session are not scored.

Four keystrokes. Four detections.

KEY	ATTACK	WHAT THE JUDGE SEES	CAUGHT BY
1	meter_spoof	CP-03 reports 5 kW while drawing ~120 kW → energy residual climbs → red, frame dropped, station quarantined, alert	R6 + Tier-2
2	fleet_oscillate	1 Hz start/stop across the fleet → transformer gauge swings → fleet-wide badge	R3
3	session_shadow	duplicate handshake on a live cpid → shadow socket refused at the handshake	R4
4	subtle_drift	-2%/tick compounding under-report → no Tier-1 rule fires → Risk Index rises past 0.65, amber badge	Tier-2 only
r	reset	clears quarantine, reconnects the fleet clean – ready for the next attack	—

The subtle_drift beat is the pitch: the one attack a rule engine structurally cannot catch, and the reason Tier-2 exists.

What is real, and what is simulated.

REAL

- OCPP 1.6-J wire format, array framing, CALL/CALLRESULT correlation
- Per-station session FSM and transaction registry
- All detection logic — Tier-1 rules R1-R6, Tier-2 Isolation Forest + CUSUM maths
- Active quarantine: ChangeAvailability downstream, socket close 4001, un-quarantine on reconnect
- Forensic JSON logging and the live NOC dashboard

SIMULATED / IN PROGRESS

- Charger fleet physics — a CC-CV battery model, not real hardware
- The CSMS backend — an ~80-line mock, swappable for SteVe or CitrineOS
- The attacks — synthesised; there is no public labelled OCPP-attack corpus
- Tier-2 baseline is fit on a recorded feed fixture, not yet an external dataset
- End-to-end added-latency instrumentation

Measured, not asserted.

82

automated tests passing — rules, ML engine, OCPP parsing, battery model, dataset loader

~9 μ s

Tier-1 rule evaluation per frame (mean); p99 < 25 μ s over 200k frames

6 + 2

deterministic rules live, plus a two-model Tier-2 (Isolation Forest + CUSUM)

- Tier-2 is wired into the live relay — every telemetry frame carries a Risk Index; both meter-spoof and drift are flagged in the offline benchmark.
- Open before final rehearsal: tune drift rate for a visible on-stage climb; re-fit Tier-2 on a real dataset (ACN-Data / ElaadNL); instrument end-to-end latency.

A real path to production.

● Protocol

OCPP 2.0.1 device model, the three security profiles (Basic / TLS / mutual-TLS), ISO 15118 Plug & Charge, smart-charging profiles.

● Deployment

Runs as a CPO ingress sidecar. Horizontal scale via cpid-consistent-hash routing with Redis-backed shared registries. Tested inline against a real open-source CSMS (SteVe / CitrineOS).

● Detection

Tier-2 retrained on real fleet CDRs; per-station personalisation; federated learning across CPOs so the model improves without sharing raw session data.

Capacity math from the measured Tier-1 cost: one instance sustains thousands of frames/sec; a 10k-charger CPO at 0.1 Hz MeterValues $\approx$ 1k fps — a handful of instances.

Inline. Transparent. Sub-millisecond.

A drop-in security layer for EV charging that catches billing fraud, grid attacks, session hijacks — and the slow drift a rule engine never will.

```
python -m simulator.csms
```

→

```
python -m proxy.main
```

→

```
python -m simulator.twin
```

→

```
npm run dev
```